what is SQL Injection?

SQL injection is a technique used to extract user data by injecting web page inputs as statements through SQL commands. Basically, malicious users can use these instructions to manipulate the application's web server.

- SQL injection is a code injection technique that can compromise your database.
- It is one of the most common web hacking techniques.
- SQL injection is the injection of malicious code into SQL statements via web page input.

SQL injection can be done with the following intention:

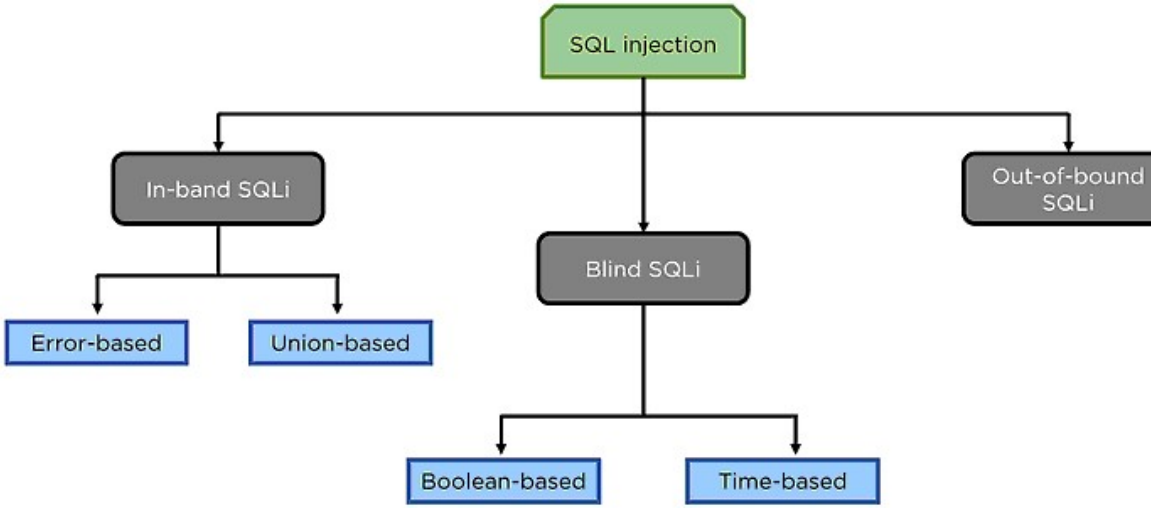
- To develop the old database of the system.
- To modify the content of the database.
- To perform different queries that are not allowed by the application.

INJECTIONS are normally placed in **Address bar** , **Search field** , **Address field** etc.

Example of SQL Injection

- Suppose we have an application based on student records. Any student can view only his or her own records by entering a unique and private student ID.
- Retrieving hidden data,where you can modify a SQL query to return additional results.

Types of SQL Injection



In-band SQLi :

In this the attackers use the same communication channel to launch their attacks and collect results.

The two common types of in-band SQL injections are Error-based SQL injection and Union-based SQL injection :

Error-based SQL injection :

Here, the attacker performs certain actions that cause the database to generate error messages. Using the error message, you can identify what database it utilizes, the version of the server where the handlers are located, etc.

Union-based SQL injection:

Here, the UNION SQL operator is used in combining the results of two or more select statements generated by the database, to get a single HTTP response. You can craft your queries within the URL or combine multiple statements within the input fields and try to generate a response.

Blind SQLi :

Here, it does not transfer the data via the web application. The attacker can not see the result of an attack in-band.

Boolean-based SQL Injection :

Here, the attacker will send an SQL query to the database asking the application to return a different result depending on whether the query returns True or False.

Time-based SQL Injection :

In this attack, the attacker sends an SQL query to the database, which makes the database wait for a particular amount of time before sharing the result. The response time helps the attacker to decide whether a query is True or False.

Out-of-bound SQL Injection :

Out-of-bound is not so popular, as it depends on the features that are enabled on the database server being used by the web applications. It can be like a misconfiguration error by the database administrator.

Basic overview of How Does SQL Work

An SQL injection attack consists of an insertion or injection of a SQL query via the input data from the client to the application. SQL commands are injected into data-plane input that affect the execution of predefined SQL commands.

How Does SQL Work On a Website?

A website has three major components — Frontend, Backend, and Database.

At the frontend, a website is designed using HTML, CSS, and JavaScript. At the backend, you have scripting languages such as Python, PHP, Perl, etc. The server side has databases such as MySQL, Oracle, and MS SQL Server, to execute the queries.

When you write a query, you generally send a get request to the website. Then, you receive a response from the website with HTML code.

Using the Postman API tool, you can test the responses that you get from various websites.

How can a SQL Injection can be detected?

SQL injections can be detected manually by testing every entry point in an application. Automated tooling can also identify SQL injection vulnerabilities by testing at each possible point in an application. These tests include:

- submission of a single quote character: Looking for errors and anomalies
- Submission of time delay payloads: Determining response time differences
- Submission of out-of-band application security testing (OAST) payloads: Checking for out-of-band network interactions .

Some signs of SQL injection include:

- A large volume of queries with unexpected structure
- Frequent redirects, ads, and popups linked to your website
- Access request to database metadata and structure information
- Requests about the structure of dynamic SQL queries, as performed by other users

ATTACKS:

Encrypted Injection Attacks

These attacks involve injecting encrypted code into a system, often delivered via phishing emails. Older software systems may not properly inspect and filter encrypted traffic, allowing the attack to bypass firewalls.

SQL Injection Attacks:

Injecting malicious SQL commands to bypass database or user system firewalls and access sensitive data.

phising attack:

SQL injection is a technique often used to attack data driven applications. Phising is nothing but cloning of website in such a way that it looks like the original website.Through which the the attacker gets the user id and password of the user.

How to Prevent SQL injection?

1. **<u>Use prepared statements and parameterized queries</u>** :

Parameterized statements ensure that the parameters passed into the SQL statements are treated safely.

2. **<u>Object-relational mapping :</u>**

Most development teams prefer to use Object Relational Mapping frameworks to translate SQL result sets into code objects more seamlessly.

3. **<u>Escaping inputs :</u>**

It is a simple way to protect against most SQL injection attacks. Many languages have standard functions to achieve this. You need to be aware while using escape characters in your code base where an SQL statement is constructed.

Some of the other methods used to prevent SQL Injection are:

- Password hashing
- Third-party authentication
- Web application firewall
- Purchase better software
- Always update and use patches

- Continuously monitor SQL statements and database

IMPORTANT TERMS:

Access term:

The term where the mobile devices , computers are connected to the wireless network.

SSID:

Service Set Identifire identifies the access points. It is human readable text which broadcasted leads to the identification of the access point.

BSSID:

Mac address of the access point.

Bandwidth:

Amount of the information that can be transferred over the connection.

what is Hacking Wireless Networking ?

A wireless network refers to any type of computer network that is wireless and is commonly associated with a telecommunications network whose interconnections between nodes are implemented without the use of wires. Wireless telecommunications networks are generally implemented with some type of remote information transmission system that uses electromagnetic waves such as radio waves for the carrier. The implementation usually takes place at the physical level or layer of the network.

Advantages of Hacking Wireless Networking

Wireless networks come with excellent advantages like :

- connectivity beyond walls
- wireless connection
- easy to access internet even in areas where laying cables is difficult
- speed and sharing.

Disadvantages :

wireless networks have a few disadvantages :

- The major issue being- the questionable security.
- As communication is done through open space, it is less secure.
- Increased chance of jamming.

There are various standards for wireless transmission :

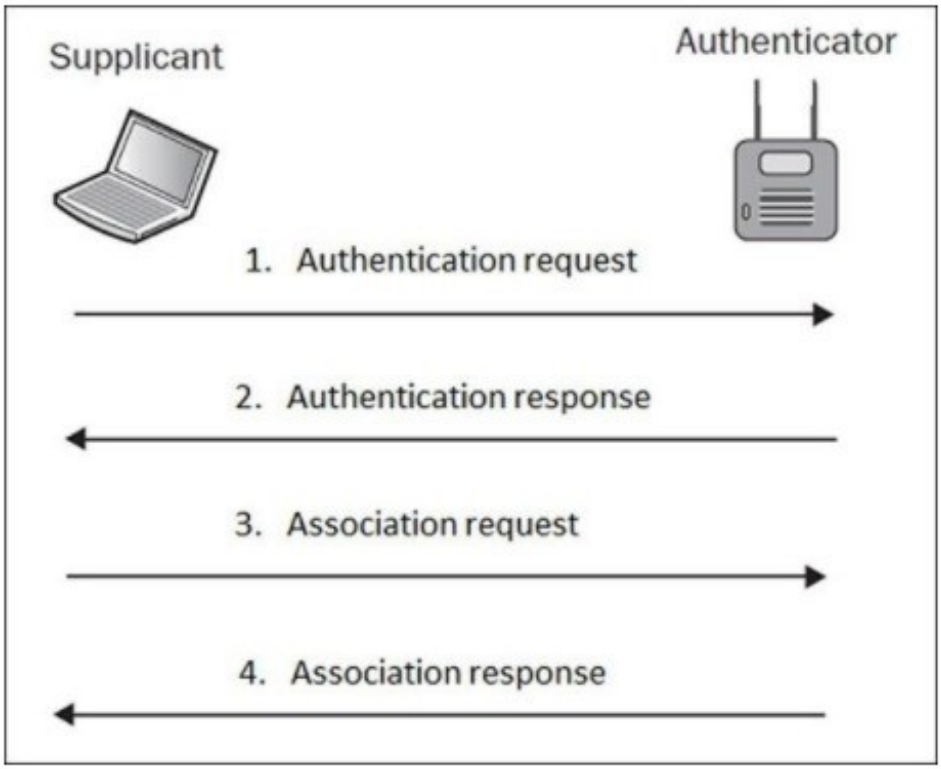
WIRELESS STANDARDS

STANDARDS	DATA RATE	FREQUENCY	RANGE
802.11a	54 mbps	5 GHz	5 ft.
802.11b	11 mbps	2.4 GHz	150 ft.
802.11g	54 mbps	2.4 GHz	50 ft.
802.11n	300 mbps	2.4 GHz & 5 GHz	175 ft.
802.11ac	1,300 Mbps upto 2,300 Mbps	5 GHz upto 8	230 ft.

AUTHENTICATION

Open Authentication:

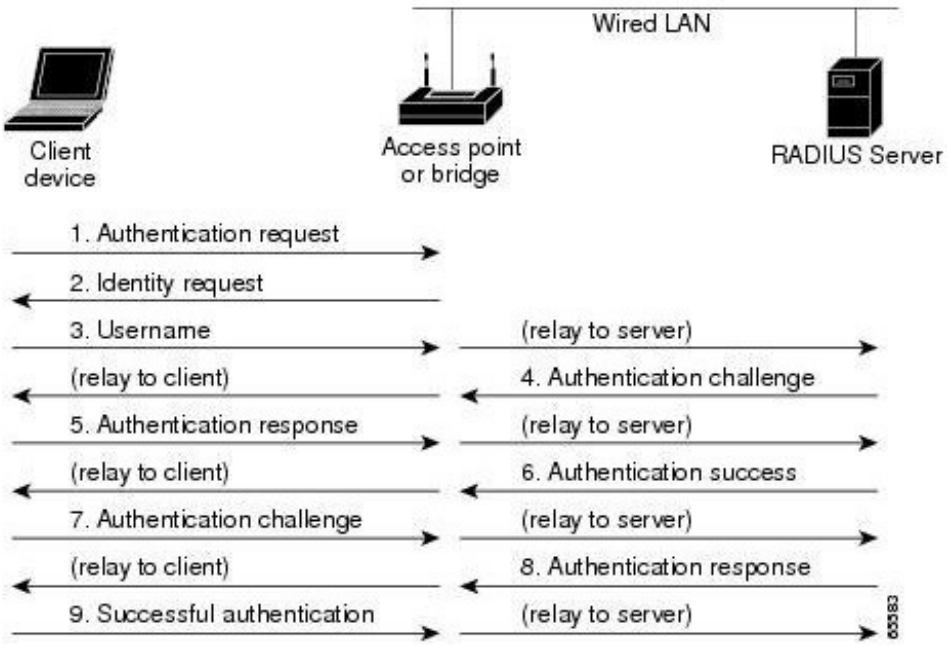
Here, the client sends a probe request, and the access point sends the probe response; then, the client requests for an authentication request, the AP sends an authentication challenge to the client. The client needs to send the shared key as authentication challenge response. AP, then, verifies the client and authenticates him/her, who then establishes a connection with the access point.



TYPES OF AUTHENTICATION

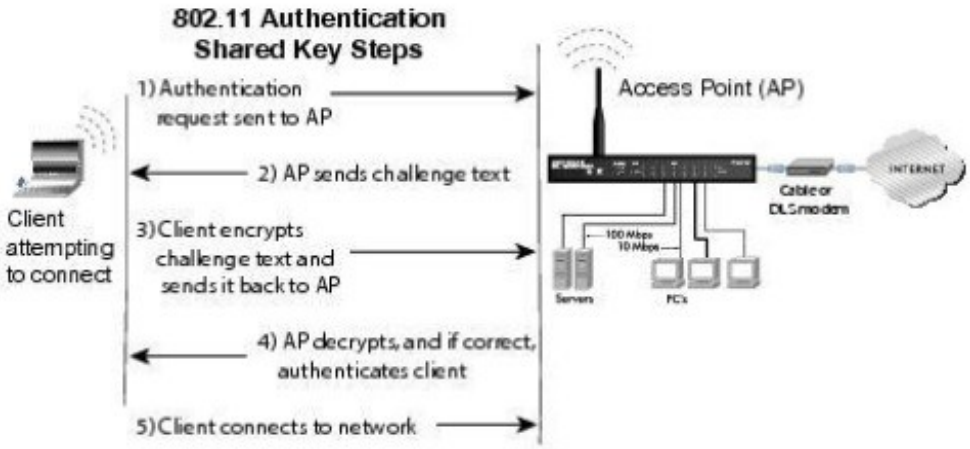
1. Centralised Authentication:

In the corporate environment, instead of an Access point verifying client's authentication details, a centralised server does the job of verifying the client. RADIUS is a centralised authentication server which verifies clients who want to connect with the access point.



2. **Shared Key Authentication:**

When a client wants to connect to an open access point he/she sends a probe request, and the AP sends a probe response; the client then sends an authentication request. Upon receiving a response, the client establishes an association with the AP.



VIRUSES AND WORMS

what is Viruses?

A virus is a type of malicious software, or malware, that can cause damage to data, files, and software through replication. It is a self-replicating program that produces its own copy by attaching itself to another program, computer boot sector or document. It infects other programs, Alters Data. Transforms itself. Encrypts Itself.

To clean the virus's infection or stop spreading it further, the user must scan the device using antivirus software and remove the infected files. Sometimes, formatting an entire system is the only option to remove the infection completely.

Types of viruses

There are various types of viruses some of them are :

1. **File Virus** :

This type of virus infects the system by appending itself to the end of a file. It changes the start of a program so that the control jumps to its code. After the execution of its code, the control returns back to the main program. Its execution is not even noticed. It is also called a Parasitic virus because it leaves no file intact but also leaves the host functional.

2. **Boot sector Virus:**

It infects the boot sector of the system, executing every time system is booted and before the operating system is loaded. It infects other bootable media like floppy disks. These are also known as memory viruses as they do

not infect the file systems.

3. **Source code Virus**:

It looks for source code and modifies it to include virus and to help spread it.

4. **Encrypted Virus:**

In order to avoid detection by antivirus, this type of virus exists in encrypted form. It carries a decryption algorithm along with it. So the virus first decrypts and then executes.

what does virus do?

Some computer viruses are programmed to harm your computer by damaging programs, deleting files, or reformatting the hard drive. Others simply replicate themselves or flood a network with traffic, making it impossible to perform any internet activity. Even less harmful computer viruses can significantly disrupt your system's performance, sapping computer memory and causing frequent computer crashes.

How does a computer get a virus?

Even if you're careful, you can pick up computer viruses through normal Web activities like:

- Sharing music, files, or photos with other users
- Visiting an infected website
- Opening spam email or an email attachment
- Downloading free games, toolbars, media players and other system utilities

- Installing mainstream software applications without thoroughly reading license agreements

How do computer viruses spread?

Viruses can be spread several ways, including via networks, discs, email attachments or external storage devices like USB sticks. Since connections between devices were once far more limited than today, early computer viruses were commonly spread through infected floppy disks.

Most,computer viruses require a user to take some form of action, like enabling “macros” or clicking a link, to spread.

What are the symptoms of a computer virus?

Your computer may be infected if you recognize any of these malware symptoms:

- Slow computer performance
- Erratic computer behavior
- Unexplained data loss
- Frequent computer crashes

How are computer viruses removed?

Antiviruses have made great progress in being able to identify and prevent the spread of computer viruses. When a device does become infected, though, installing an antivirus solution is still your best bet for removing it. Once installed, most software will conduct a “scan” for the malicious program. Once located, the antivirus will present options for its removal. If

this is not something that can be done automatically, some security vendors offer a technician's assistance in removing the virus free of charge.

Examples of computer viruses

Worms - A worm is a type of virus that, unlike traditional viruses, usually does not require the action of a user to spread from device to device.

Trojans - As in the myth, a Trojan is a virus that hides within a legitimate-seeming program to spread itself across networks or devices.

Ransomware - Ransomware is a type of malware that encrypts a user's files and demands a ransom for its return. Ransomware can be, but isn't necessarily, spread through computer viruses.

Computer virus protection

Take these steps to safeguard your PC with the best computer virus protection:

- Use antivirus protection and a firewall
- Get antispyware software
- Always keep your antivirus protection and antispyware software up-to-date
- Update your operating system regularly
- Increase your browser security settings
- Avoid questionable Websites
- Only download software from sites you trust.
- Carefully evaluate free software and file-sharing applications before

downloading them.

- Don't open messages from unknown senders
- Immediately delete messages you suspect to be spam.

Worms

What is Worms?

A computer worm is a self-replicating program that can spread from computer to computer without human intervention. Worms can use a computer network to spread themselves, relying on security failures on the target computer to access it. Worms can cause at least some harm to the network, even if only by consuming bandwidth.

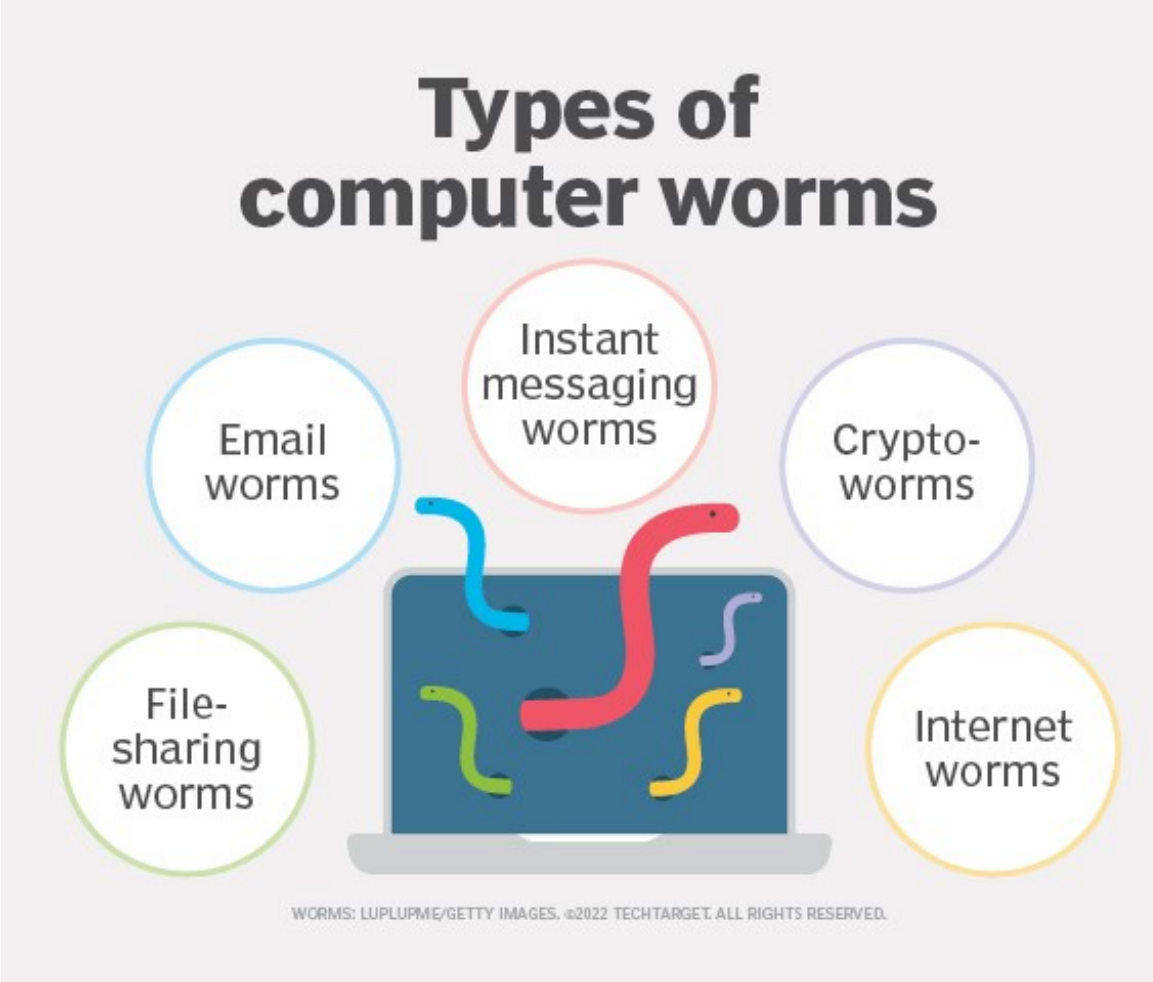
How do computer worms work?

Computer worms often rely on vulnerabilities in networking protocols, such as File Transfer Protocol, to propagate.

After a computer worm loads and begins running on a newly infected system, it will typically follow its prime directive: to remain active on an infected system for as long as possible and spread to as many other vulnerable systems as possible.

What types of computer worms exist?

There are several types of malicious computer worms:



Email worms:

Email worms work by creating and sending outbound messages to all the addresses in a user's contact list. The messages include a malicious executable file that infects the new system when the recipient opens it.

File-sharing worms:

File-sharing worms copy themselves into shared folders and spread through peer-to-peer file-sharing networks. Worm authors often disguise these malicious programs as media files.

Instant messaging worms:

Like email worms, instant messaging worms are masked by attachments or links, which the worm continues to spread to the infected user's contact list. The only difference is that instead of arriving in an email, it comes as an instant message on a chat service.

Cryptoworms

Cryptoworms work by encrypting data on the victim's system. Perpetrators can use this type of worm in ransomware attacks, where they follow up with the victim and demand payment in exchange for a key to decrypt the files.

Internet worms:

Some computer worms specifically target popular websites with poor security. If they can infect the site, they can infect a computer accessing the site.

How do computer worms spread?

While some computer worms require user action to initially propagate, such as clicking on a link, others can easily spread without user interaction. All that's necessary is for the computer worm to become active on an infected system. Once active, the worm can spread over a network through its internet or local area network.

Before the widespread use of networks, computer worms spread through infected storage media, such as floppy disks, which, when mounted on a system, would infect other storage devices connected to the victim system.

Computer worm examples:

- The Morris worm

- The ILOVEYOU worm
- Stuxnet
- WannaCry

How to prevent computer worm infections

Good cybersecurity hygiene is essential to protect systems from computer worms. The following measures can help prevent the threat of computer worm infections:

- Install operating system updates and software patches.
- Use firewalls to protect systems from malicious software.
- Use antivirus software to prevent malicious software from running.
- Never click on attachments or links in emails or other messaging applications that might expose systems to malicious software.
- Use encryption to protect sensitive data stored on computers, servers and mobile devices.

How to detect a computer worm

Signs that indicate a worm might be present include the following symptoms:

- computer performance issues over time, or limited computing bandwidth with no apparent explanation.
- the system freezing or crashing unexpectedly.unusual system behavior, including programs that execute or terminate without user interaction;
- unusual sounds, images or messages;

- the sudden appearance of unfamiliar files or icons, or the unexpected disappearance of files or icons;
- warning messages from the operating system or antivirus software; and
- email messages sent to contacts that the user didn't send.

How to remove a computer worm

Removing a computer worm can be difficult. In extreme cases, the system might need to be reformatted, requiring a user to reinstall all software.

When beginning an incident response, security teams should use a known safe computer to download any required updates or programs to an external storage device and install them on the affected machine.

If it is possible to identify the computer worm infecting the system, specific instructions or tools might be available to remove it without having to wipe the system entirely.

Disconnect the system from the internet or any wired or wireless network before attempting to remove the computer worm. Also, remove nonpermanent storage devices, such as a USB or external hard drive, and scan them separately for infection.

Once the system is disconnected, do the following:

- Update all antivirus signatures.
- Scan the computer with the up-to-date antivirus software.
- Use the antivirus software to remove any malware, malicious code and worms it finds, and clean infected files.
- Confirm that the operating system and all applications are up to date

and patched.

Key Difference between Virus, Worms and Trojan Horse

	VIRUS	WORMS	Trojan Horse
Definition	Self replicating program that attaches itself to other programs and files.	Illegitimate programs that replicate themselves usually over the network.	Malicious program used to control a victim's computer from a remote location.
Purpose	Disrupt normal computer usage, corrupt user data, etc.	Install backdoors on victim's computer, slow down the user's network, etc.	Steal sensitive data, spy on the victim's computer, etc.

Difference Between Viruses and Worms

virus	worm
• A computer virus is a program, wherein a code copies itself and replicates itself to other programs/files on a device and may result in corrupting or damaging the device.	• A computer worm is an independent malicious program, which when enters a system can start causing harm/damage to the device.
• An initiation is required by the host, i.e., a virus spreads only when an infected program is executed in a device	• A worm only needs to enter the device, then it can automatically affect the other files and programs. No execution is needed
• Few different types of computer viruses include: 1. Boot sector virus 2. Direct Action virus 3.Polymorphic virus 4.Macro virus 5.Spacefiller virus 6.Overwrite virus 7.File Infector virus	• Few of the different types of computer worms are as follows: 1. Internet worms 2. Instant messaging worms 3. Email worms 4. File sharing worms 5. Internet relay chat (IRC) worms
• A virus may spread when a file is open and then the same malicious code is copied and	• A worm only requires a medium to enter the device. This may be through the internet, email, online messaging applications, etc.
• spread around whenever other files are opened in the host computer.	• A worm can quickly spread through a device.
• Time taken by a virus to	

what is physical security ?

Physical security is the protection of personnel,hardware, software, networks and data from physical actions and events that could cause serious loss or damage to an enterprise, agency or institution. This includes protection from fire, flood, natural disasters, burglary, theft, vandalism and terrorism.

The physical security framework is made up of three main components: access control, surveillance and testing.

Access control

The key to maximizing one's physical security measures is to limit and control what people have access to sites, facilities and materials. Access control encompasses the measures taken to limit exposure of certain assets to authorized personnel only. Examples of these corporate barriers often include ID badges, keypads and security guards. However, these obstacles can vary greatly in terms of method, approach and cost.

Surveillance

This is one of the most important physical security components for both prevention and post-incident recovery. Surveillance, in this case, refers to the technology, personnel and resources that organizations use to monitor the activity of different real-world locations and facilities. These examples can include patrol guards, heat sensors and notification systems.

The most common type of surveillance is closed circuit television (CCTV) cameras that record the activity of a combination of areas. The benefit of these surveillance cameras is that they are as valuable in capturing criminal behavior as they are in preventing it. Threat actors who see a CCTV camera

are less inclined to break in or vandalize a building out of fear of having their identity recorded. Similarly, if a particular asset or piece of equipment is stolen, surveillance can provide the visual evidence one needs to identify the culprit and their tactics.

Testing

Physical security is a preventative measure and incident response tool. Disaster recovery (DR) plans, for example, center on the quality of one's physical security protocols -- how well a company identifies, responds to and contains a threat. The only way to ensure that such DR policies and procedures will be effective when the time comes is to implement active testing.Testing is increasingly important, especially when it comes to the unity of an organization.

Importance of physical security

As businesses become more dependent on the internet of things (IoT), so does the need for digital and physical security. IoT demands a significant amount of physical security to safeguard data, servers and networks. The rising interconnectedness of IoT has expanded the sphere of physical security. Virtual machines (VMs) and applications that run in the cloud, for example, are only as protected as their physical servers.

Physical security examples

Physical security can take many shapes and forms. The strategies, barriers and techniques that organizations use to support general physical information technology (IT) security, for example, are significantly different from those used to facilitate consistent physical network security. Here are a few physical security examples used to contain and control real-world threats.:

Log and trail maintenance

Keeping a record of what is accessed -- and what people attempt to access -- is a reliable way to not only discourage unauthorized users, but create a forensic-friendly data environment.

Multiple failed login attempts and attempted access using a lost card are both physical security tools that organizations can use to reliably track their asset activity. In the case of a security breach, these records can prove incredibly valuable for identifying security weaknesses.

Risk-based approach

One of the most effective ways to optimize a physical security investment is to use a risk-based approach. This is a data analysis technique used to evaluate scenarios based on one's risk profile.

If a business is particularly risk-averse -- such as a credit union or a restaurant -- it will opt to invest in a more expensive physical security system that is more equipped to mitigate risk. Therefore, the amount of resources a company dedicates to its physical security using a risk-based approach should be equivalent to the value it places on risk mitigation.

Accountable access control

By tying access control to individuals, an organization can improve its visibility over personnel activity. Imagine a particular room can only be accessed by a single key, and that key is given to two people. If an asset in that room goes missing, then only those two people are accountable for its disappearance.

Linux Hacking: Linux Hacking

Linux plays a significant role in ethical hacking due to its:

- **Open-source nature**: Allows for in-depth understanding of the operating system's functionalities and potential security risks.
- **Command-line interface**: Offers a powerful and flexible environment for executing various hacking tools.

Popular tools:

- **Kali Linux**: A distribution specifically designed for penetration testing, containing numerous security testing tools. (Important note: Downloading and using Kali Linux should only be done with explicit permission and within legal boundaries).

Malicious actors typically use tools such as password crackers, network and vulnerability scanners, and intrusion detection software. These Linux hacking tools all serve different purposes and are used for a wide range of attacks.

- Password crackers are software developed for decoding passwords in a variety of formats, such as encrypted or hashed passwords. Many cracking distros offer additional functionality such as network detectors and wireless packet sniffing. Malicious actors use these Linux hacking tools because they offer a simple way to gain access to an organization’s network, databases, directories, and more. Password cracking distros are commonly used in Linux wifi hacking

(Linux hacking that targets wireless networks).

- Linux network scanners are used to detect other devices on a network. In doing so, attackers are able to develop a virtual map of the network. In addition to discovering other devices, many network scanners are capable of gathering details about devices such as which operating systems, software, and firewalls are being used. Network scanners are used to discover network security holes in Linux wifi hacking. They also can be used to gather information useful for Linux distro hacking (Linux hacking that targets software, applications, operating systems, etc).

- Linux vulnerability scanning software is used to detect vulnerabilities in systems and applications. Malicious parties often use vulnerability scanners as Linux hacking software in order to detect exploitable vulnerabilities, gather simple passwords, discover configuration issues, and perform denial of service attacks. Vulnerability scanners are frequently used for Linux distro hacking because of these capabilities.

Linux Hacking Prevention and Mitigation

Fortunately, there are measures that organizations and individuals can take to lessen the risk and threat of Linux hacking. Many of these security procedures use the same tools that malicious parties abuse in Linux hacking. Organizations can use the tools discussed above (password crackers, network scanners, vulnerability scanners, wireless sniffers, intrusion detection systems, etc.) to test their software and networks from a hacker's perspective. Regular testing and monitoring using Linux hacking software gives organizations the opportunity to discover software and network vulnerabilities before attackers.

Focus:

Ethical hackers leverage Linux skills to:

- **Simulate attacks**: Identify weaknesses in systems and networks.
- **Perform vulnerability assessments**: Evaluate the security posture of systems.
- **Develop security tools**: Enhance overall cyber defense.

Why is Linux Hacked?

Linux is often hacked by malicious actors to gain unauthorized access to systems and steal data. This type of hacking is done to exploit vulnerabilities in Linux applications, software, and networks. Linux is often used for penetration testing because it is an open-source operating system that provides many tools that can be used for security analysis. Linux is also very easy to modify or customize, and there are many Linux security distros available that can be used as Linux hacking software.

Evading IDS and Firewalls: Evading IDS and Firewalls

Evading Intrusion Detection Systems (IDS) and firewalls is a common tactic used by attackers to gain unauthorized access to networks and systems. Here are some of the most **effective techniques** for evading both IDS and firewalls, as outlined in the provided sources:

1. Packet Fragmentation

This technique involves splitting packets into smaller fragments before sending them to the target network. Most IDS are configured to skip

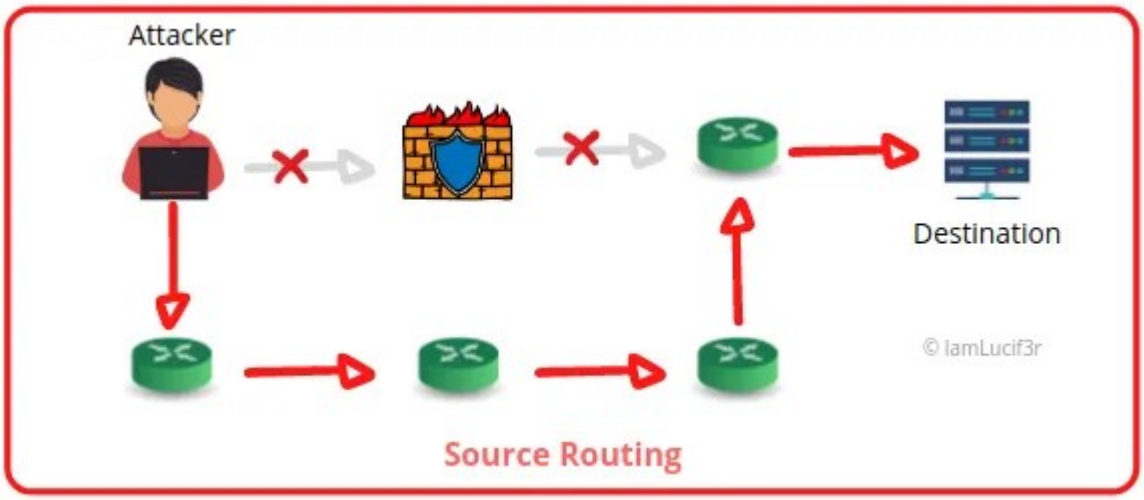
fragmented packets, allowing the attacker to evade detection.

Tools

NMAP or fragroute can be used for splitting packets into smaller fragments .

2. **Source Routing**

By manipulating the routing information in IP packets, attackers can direct packets through a path that avoids firewalls and IDS. This technique forces the packets to take a different route to reach their destination, potentially bypassing security measures .

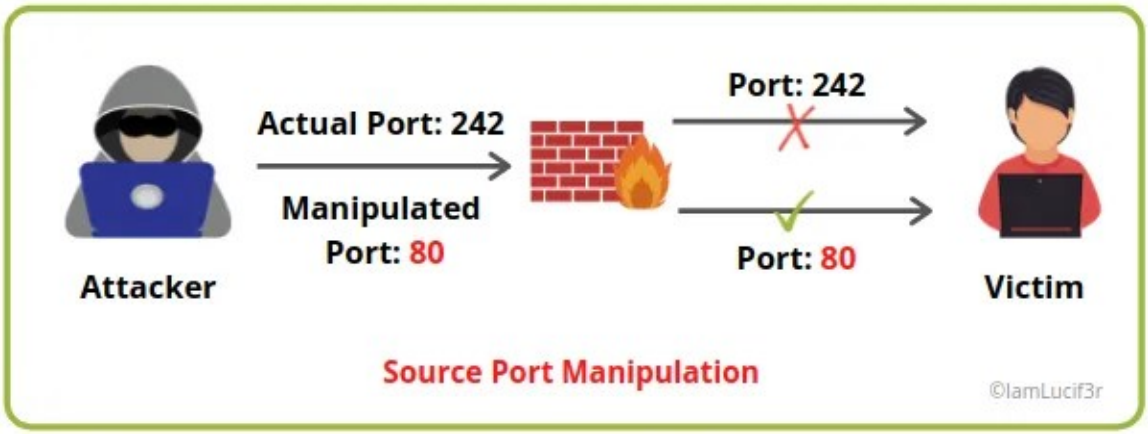


3. **Source Port Manipulation**

This involves changing the source port number of packets to a common port number (e.g., HTTP, DNS, FTP) that is allowed by the firewall or IDS configuration. This can help evade detection by making the traffic appear legitimate .

Tools:

NMAP with the -g or --source-port <port number> option can be used for this purpose .



4. IP Address Decoy

Generating or manually specifying decoy IP addresses can make it difficult for IDS/firewalls to identify the actual source of the traffic. This technique can be used to confuse the target's security systems.

tools:

NMAP's decoy scan function can be used to generate multiple IP addresses for scanning.

5. Spoofing the IP Address

By altering packet headers to make them appear as if they are coming from a legitimate source, attackers can bypass firewalls that filter packets based on source IP address. This technique is often used in conjunction with IP

spoofing.

Tools: Hping3 can be used for IP address spoofing.

6. Customizing Packets

Creating custom packets with specific payloads or headers can help evade detection by IDS/firewalls. This can be achieved using packet crafting tools or by appending custom binary data, strings, or random data to packets .

Tools:

Tools like Colasoft Packet Builder or NetScanTools Pro can be used for packet crafting. NMAP can be used for appending custom binary data or strings.

7. Sending Bad Checksums

Sending packets with incorrect TCP/UDP checksums can bypass systems that do not properly verify these checksums. This can help attackers gain information from improperly configured systems.

8. Randomizing the Order of Hosts

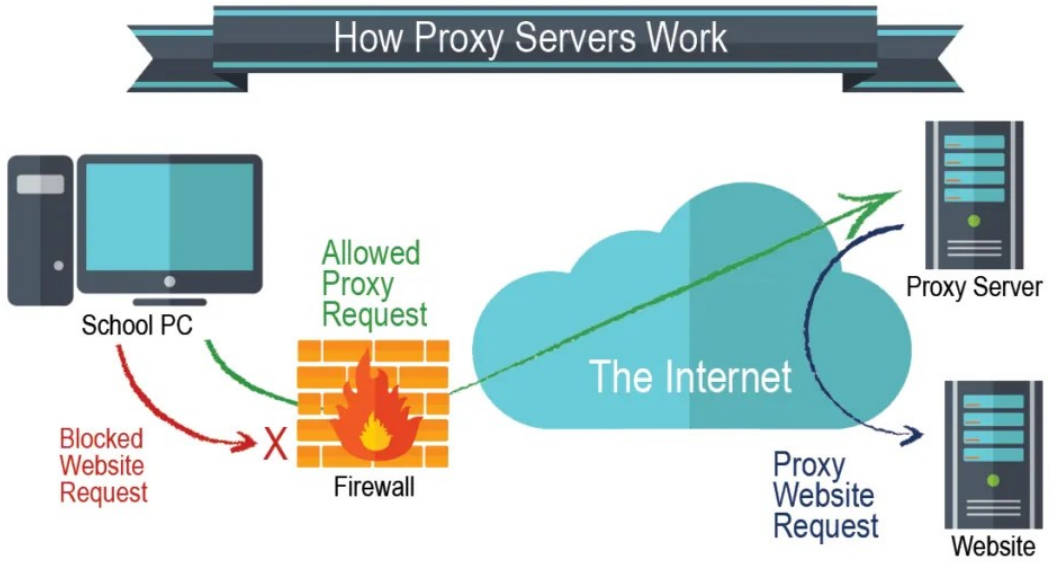
Randomizing the order in which hosts are scanned can make the scan less noticeable to network monitoring systems and firewalls. This can be achieved using NMAP with specific options.

9. Anonymizers

An anonymizer acts as an intermediary server between the attacker and the target, making the attack untraceable. This can help bypass IDS and firewall rules while ensuring privacy .

10. **Proxy Servers**

A proxy server is an application that can serve as an intermediary for connecting with other computers. A proxy server is used to fulfill the various purposes of firewall/IDS evasion, masquerading the original source, remotely accessing intranets, etc. The following image explains the working of a proxy server.



These techniques highlight the importance of maintaining up-to-date security measures and regularly testing the effectiveness of firewalls and IDS systems against potential evasion tactics. Ethical hackers and security professionals can use these insights to improve network security and protect against unauthorized access.

Types of Evasion Technique For IDS

IDS stands for Intrusion Detection System. It is used to monitor traffic entering any network and helps in detecting malicious activity. It is important to note that IDS only detects malicious activities, and does not prevent attacks.

1. Packet Fragmentation: In this technique, the IP packets are split into smaller fragments. By doing this, the TCP header is split across multiple fragments. When IDS encounter the packets, they enqueue them for checking any malicious activity. However, as the number of fragments increases, there is an increase in the CPU and network bandwidth consumption. For this reason, IDS ignores evaluating such packets. Hence, these fragments may pass undetected through the IDS.

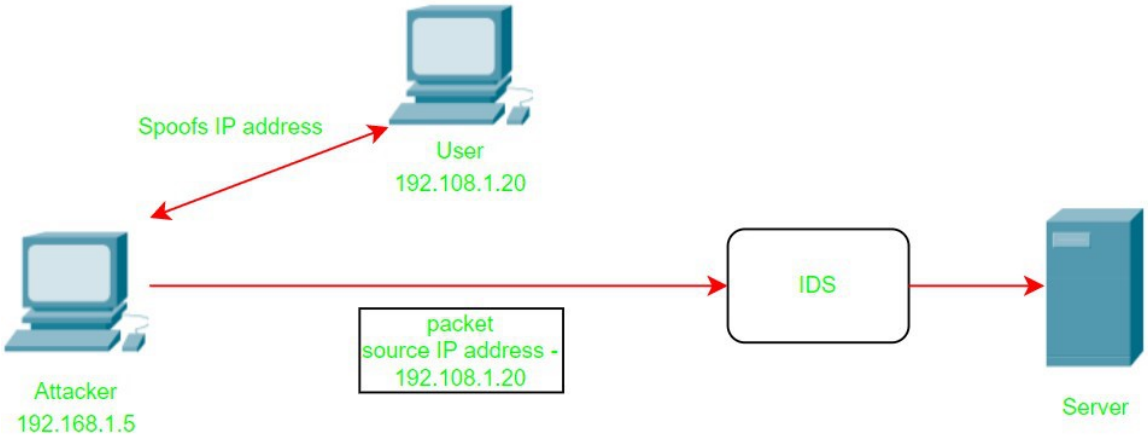
2. Source Routing: Packets pass through a number of routers before reaching the target host. Routers consult the routing table to pass the packet to the next hop. IDS are also put in place to monitor the network traffic. However, the route taken by the packets can be manipulated by the attacker. The attacker can make sure that the packets take a route that does not contain the IDS.

3**. Source Port Manipulation:** Sometimes IDS might allow network packets to pass without any inspection if they arrive at a particular port like port 80 which is primarily used for HTTP. This improper configuration can be exploited by attackers by manipulating the source port of packets. Hence, packets arriving at such ports can go unnoticed by the IDS.

4. IP Address Decoy: The attacker sends packets to the target host by using the IP addresses of other hosts. So different packets have different IP addresses. Hence, it becomes difficult for the IDS to identify the actual IP

address of the attacker. However, one of the packets has the actual IP address of the attacker, and if the IDS is configured to block traffic from all these IP addresses then the attacker cannot evade the IDS. This technique is used to scan ports at the target host. So an attacker can identify whether a particular port at the target host is running or not.

5. IP Address Spoofing: IP Address Spoofing simply means using some other machine's IP address to send packets to the target host. Again, this technique can be used to scan ports which are usually done before the actual attack. So the IDS may identify the innocent hosts as malicious ones. However, using NMAP for performing IP address spoofing won't produce useful results as the reply packets from the target host will be sent to the spoofed IP address. -S <ip-address> option can be used to perform IP address spoofing.



6. Customizing Packets: IDS can be evaded by customizing the data packets. Customizing can be done by replacing data in the payload or appending data to the payload. Following are some ways to customize data-

(a) **Unicode-based Evasion:** Unicode is used to represent characters from

different languages, emojis, etc. So, the payload can contain Unicode representation of data. However, a message having the same meaning could be represented using a different Unicode. By replacing data in the payload, malicious packets can pass through a signature-based IDS if the newly created pattern is not a part of the signature set stored.

(b) **Appending binary data:** This appends binary data to the payload. The data to be appended must be specified in hexadecimal.

nmap <target ip-address> --data 0xabcdefab

(c) **Appending string:** This appends a regular string to the payload.

nmap <target ip-address> --data-string "danger"

(d) **Appending random data:** This appends random data of specified length to the payload. Length can be anything between 0-65400. However, values greater than 1400 are not recommended as they could be greater than MTU.

nmap <target ip-address> --data-length <length>

what is firewall in ethical hacking

A firewall is a sort of gatekeeper that logs, inspects, and sometimes blocks the traffic entering and sometimes leaving your network. The firewall is an old security technology that has evolved to include new capabilities and variations to meet the demands of networks. What started as a manually controlled gatekeeper has turned into a smart inspection tool that exists on local servers and in the cloud.

What Are the Capabilities and Limits of a Firewall?

A firewall is an exceptionally powerful tool for protecting your network but with a few caveats. Firewalls are meant to protect you at the packet level,

meaning they handle protocol inspections.

Firewalls can:

- Log and inspect traffic.
- Restrict traffic types based on corporate policies.
- Keep lists of allowed sources of traffic.
- Block out malicious traffic types or sources.
- Firewalls are necessary for protecting your network, but they're not flawless. I'll explain why.

Two types of traffic are sent over networks:

User datagram protocol (UDP): A lightweight protocol that doesn't require any "handshakes" between the device requesting the traffic and the source delivering the traffic. So UDP traffic can stream data like gaming, video, or streaming service sites to recipients. However, this content stream isn't guaranteed, which occasionally leads to packet loss.

Transmission control protocol (TCP): This protocol requires a handshake (this synchronizes the connection between two points and acknowledges the transfer of packets) between senders and receivers to ensure quality delivery with no packet loss.

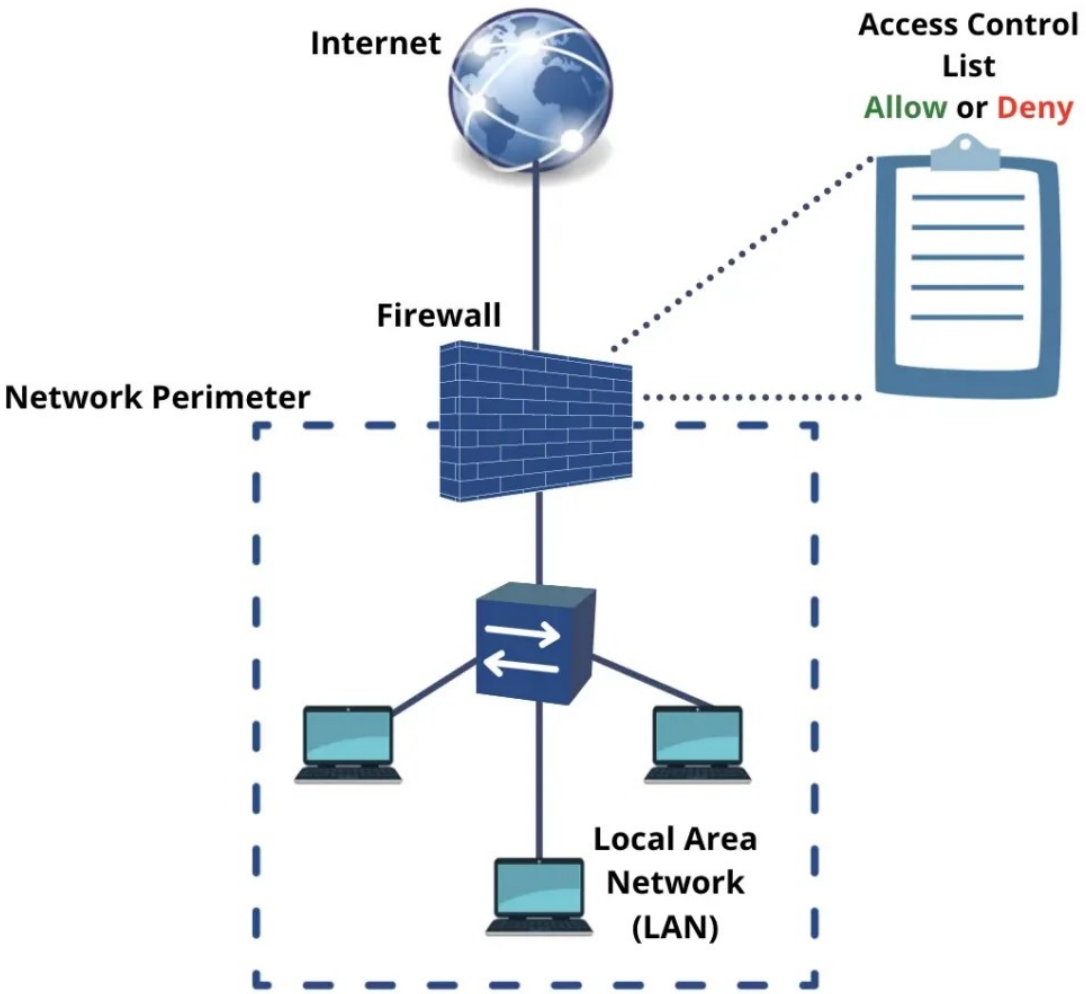
The problem with firewalls is that most of them only evaluate traffic on these basic levels without any deeper inspection. This can lead to clumsy attempts at blocking certain actions by halting certain traffic, such as YouTube videos that use UDP. This can affect the delivery of other valid traffic that uses the same protocol. An example is Zoom, which also uses UDP.

Firewalls don't inspect traffic at the application level, which is why other tools, such as secure web gateways (SWG) were created, which gives security professionals an added layer of control. Think of it this way: A firewall is a sledgehammer. In some cases, a sledgehammer is needed to fix a problem. But, in other cases, a more detailed solution is needed that a firewall can't handle.

An Overview of the Three Main Firewall Types:

Stateless packet-filtering firewall

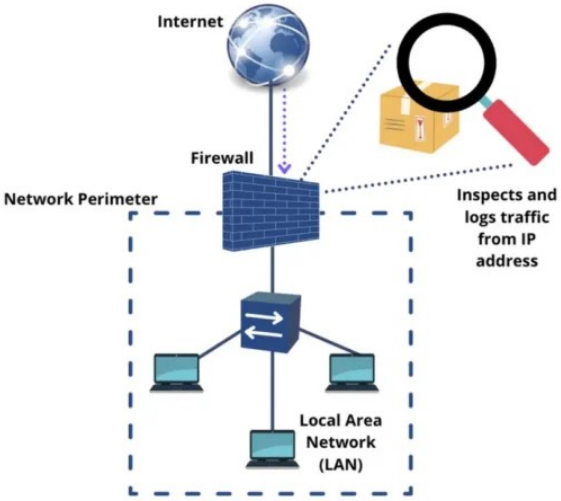
A packet filtering firewall is the oldest form of firewall. These firewalls live on the edge of a perimeter security-based network and require manual inputs from a security professional to set the parameters for traffic without any learning capabilities. An administrator creates an access control list (ACL) to either allow or deny packets from certain internet protocol (IP) addresses. It's essentially a "dumb" firewall.

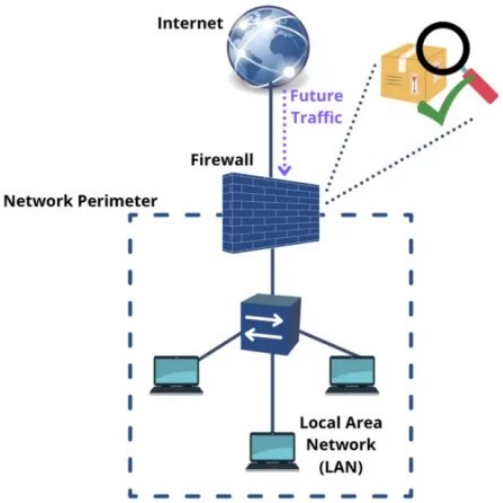


Stateful inspection firewalls

If you're looking for an upgrade from 1990s capabilities, that would be the stateful inspection firewall.

This firewall type is "stateful" because while it does use access control lists to regulate incoming and outgoing packets, the firewall also inspects packet traffic, logs the relevant data — originating address, packet type, destination, and so on — and compares future traffic against that log to validate it.

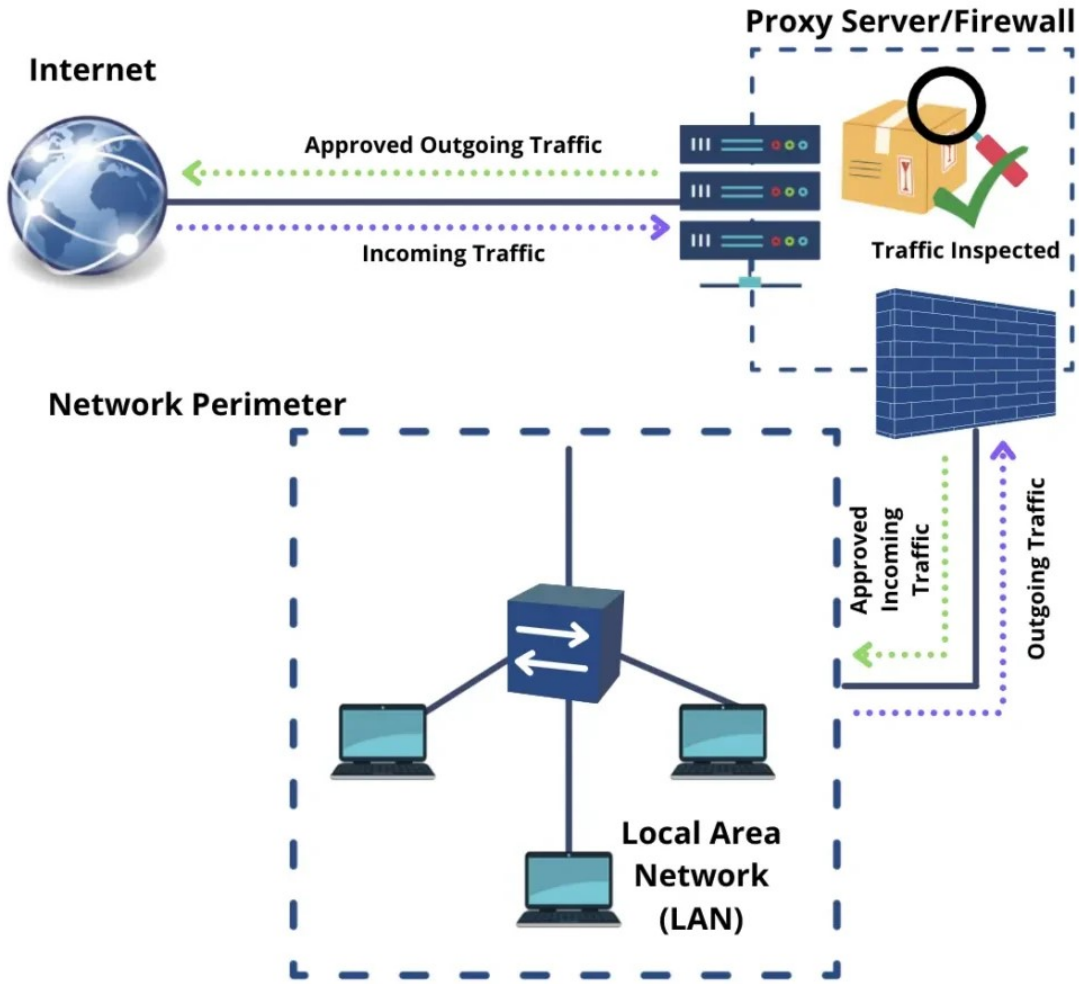




Proxy firewalls

Out of the three firewall types, a proxy firewall is the most secure. The concept works the same as using a middleman to receive sensitive materials, inspecting them at a secure location, then delivering them to you once they are declared “safe.”

Instead of allowing traffic to reach the network perimeter before it’s inspected, a proxy firewall filters packets through a server with a firewall installed:



Most proxy firewalls employ security capabilities not shared by the last two, such as:

Deep packet inspection (DPI): DPI searches for signatures of malware, outgoing sensitive data, and monitors for restricted content, such as unmanaged virtual private network (VPN) traffic or inappropriate websites.

Sandboxing: The biggest benefit of a proxy firewall is the distance it creates between threats and your network. This creates a “sandboxing” capability that allows threats to play out in a safe environment that only harms the specific firewall it contacts. Most security infrastructures create redundant

proxy firewalls that take over in case one is down.

Traffic validation: Like standard stateful firewalls, proxy firewalls also use administrative tools like ACLs and logging to validate traffic from recognized sources.